

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)**Department of Computer Science and Engineering****ASSESSMENT TOOL 3 – INCIDENT RESPONSE (MONITORING & MITIGATION)**

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 3
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Develop Incident Response Plan, Analyze Security Monitoring Dashboard, Recommend Mitigation Strategies and Technical Justification.		
Student Name:	ADHITHYAN S	Reg. No.:	192421102
Section / Batch:		Date:	

Instructions to Students

- Develop an incident response plan based on the given security incident scenario and identified findings.
- Analyze the provided security monitoring dashboard, alerts, logs and indicators to determine incident status and affected assets.
- Recommend prioritized mitigation strategies that directly address the identified threats, vulnerabilities and incident impact.
- Provide clear technical justification for each major response and mitigation decision using evidence from the scenario.
- Present the response plan, dashboard analysis and recommendations clearly and professionally within the prescribed submission format.

Question Type	Focus Area	Questions	Marks
INCIDENT RESPONSE	Monitoring & Mitigation	Q1	Q1 – 100
GRAND TOTAL:		100 Marks	

DevSecOps Security Operations Assessment

Simulated Log Analysis, Anomaly Detection, Incident Response Planning
and Security Monitoring Dashboard Evaluation

Environment: Cloud-Native CI/CD Platform (IAM, WAF, SCM, CI/CD, Cloud API, SIEM/SOAR)

Prepared by: DevSecOps / Security Operations Center (SOC)

Classification: Internal — Confidential

Table of Contents

1. Executive Summary
2. Methodology — Security Log Simulation
3. Anomaly Detection Analysis
4. Incident Timeline Analysis
5. Security Monitoring Dashboard
6. Incident Response Plan
7. Recommended Mitigation Strategies and Technical Justification
8. Conclusion

1. Executive Summary

This assessment evaluates DevSecOps security operations for a cloud-native software delivery environment by simulating 30 days of realistic security telemetry across Identity and Access Management (IAM), Web Application Firewall (WAF), Source Control Management (SCM), CI/CD pipelines, cloud API activity, and SIEM/SOAR platforms. A total of 10,123 log events were generated, including normal operational baseline traffic and one embedded multi-stage attack scenario designed to exercise detection, correlation, and response capabilities end-to-end.

Statistical and rule-based anomaly detection identified a credential-stuffing and account-takeover campaign originating from a Tor-exit-associated IP address on 18 August 2026. The attacker progressed through reconnaissance, credential stuffing, MFA-fatigue-based initial access, privilege escalation, CI/CD pipeline tampering, secrets access, data exfiltration, and log-tampering (defense evasion) before automated SOAR playbooks disabled the compromised account and blocked the source IP.

Key findings and metrics:

- Mean Time to Detect (MTTD): 156 minutes from first malicious activity to SIEM correlation alert — outside the target SLA of 15 minutes.
- Mean Time to Contain (MTTC) after detection: 7 minutes — within target SLA, reflecting effective automated response once alerted.
- Total attack-start-to-remediation window: 170 minutes, during which an estimated 3.2 GB of customer data was exfiltrated and production secrets were exposed.
- Root causes: absence of real-time correlation rules for low-and-slow reconnaissance, lack of adaptive rate-limiting on authentication endpoints, and susceptibility to MFA-fatigue (push-bombing) attacks.
- A secondary medium-severity insider-risk anomaly (after-hours bulk access to HR records) was also identified and is recommended for HR/Legal follow-up.

This document presents the simulated log methodology, the security monitoring dashboard built from the data, a full incident timeline and anomaly analysis, a structured Incident Response Plan aligned to NIST SP 800-61r2, and prioritized mitigation strategies with technical justification.

2. Methodology — Security Log Simulation

Synthetic logs were generated programmatically to model realistic organizational behavior and attacker tradecraft, avoiding reliance on any real production data. The simulation combined:

- Baseline benign activity: authentication events weighted toward business hours (Gaussian distribution centered at 13:00), routine CI/CD pipeline runs across five repositories, WAF bot/crawler blocks, and everyday cloud storage access — generated daily across a 30-day window.
- An embedded multi-stage attack scenario on 18 August 2026, modeled on a realistic account-takeover-to-exfiltration kill chain (MITRE ATT&CK-aligned): reconnaissance, credential access, initial access, privilege escalation, execution via CI/CD tampering, exfiltration, and defense evasion.
- A secondary insider-risk anomaly: after-hours bulk access to a sensitive HR data repository by a legitimate but atypical account.

2.1 Data Sources Simulated

Source	Description	Approx. Volume
IAM	SSO login success/failure, MFA events, role changes	6,791 events
Cloud API	Object storage access, bucket policy changes, audit trail control	1,725 events
WAF	Bot/crawler blocks, endpoint scanning detections	898 events
CI/CD	Pipeline builds/deploys, secrets vault access	705 events
SCM	Source commits, branch protection events	1 event (incident)
SIEM / SOAR	Correlation alerts, automated containment actions	3 events (incident)

2.2 Representative Log Sample

The excerpt below illustrates the transition from normal baseline events to the escalating severity of the injected incident (full extracted incident timeline in Section 4).

Timestamp (UTC)	Source	Event Type	Actor	Src IP	Severity	Details
2026-08-01 00:02:58	IAM	LOGIN_SUCCESS	user012@corp.io	10.20.2.235	INFO	Successful login from DE
2026-08-01 02:19:00	CI_CD	PIPELINE_RUN	svc-ci-runner	10.20.1.15	INFO	Build+deploy completed: payments-api
2026-08-18 02:00:00	WAF	SCAN_DETECTED	—	185.220.101.47	MEDIUM	Endpoint enumeration: /api/v1/admin

Timestamp (UTC)	Source	Event Type	Actor	Src IP	Severity	Details
2026-08-18 02:45:00	IAM	LOGIN_FAILURE	user017@corp.io	185.220.101.47	HIGH	Credential-stuffing pattern
2026-08-18 03:11:00	IAM	LOGIN_SUCCESS	user017@corp.io	185.220.101.47	CRITICAL	Impossible travel: IN→RO, 9200km/38min
2026-08-18 03:38:00	IAM	MFA_APPROVED	user017@corp.io	185.220.101.47	CRITICAL	Approved after 9 consecutive pushes
2026-08-18 03:41:00	IAM	ROLE_MODIFIED	user017@corp.io	185.220.101.47	CRITICAL	Role escalated Developer→Admin
2026-08-18 03:50:00	SCM	COMMIT_PUSHED	user017@corp.io	185.220.101.47	CRITICAL	Force-push bypassing branch protection

3. Anomaly Detection Analysis

Two complementary detection techniques were applied to the simulated telemetry:

- Statistical baselining (Z-score): hourly failed-login counts were modeled against a 30-day baseline (mean = 0.31/hr, std dev = 1.42/hr). Any hour exceeding the mean by more than 3 standard deviations (threshold = 4.56 failed logins/hour) was flagged as anomalous.
- Rule-based / rare-event correlation: event types occurring fewer than 10 times across the entire 30-day dataset (e.g., ROLE_MODIFIED, SECRET_ACCESSED, CLOUDTRAIL_STOPPED) were treated as inherently high-signal and cross-referenced by actor and source IP to reconstruct attacker sessions.

3.1 Detected Anomalies

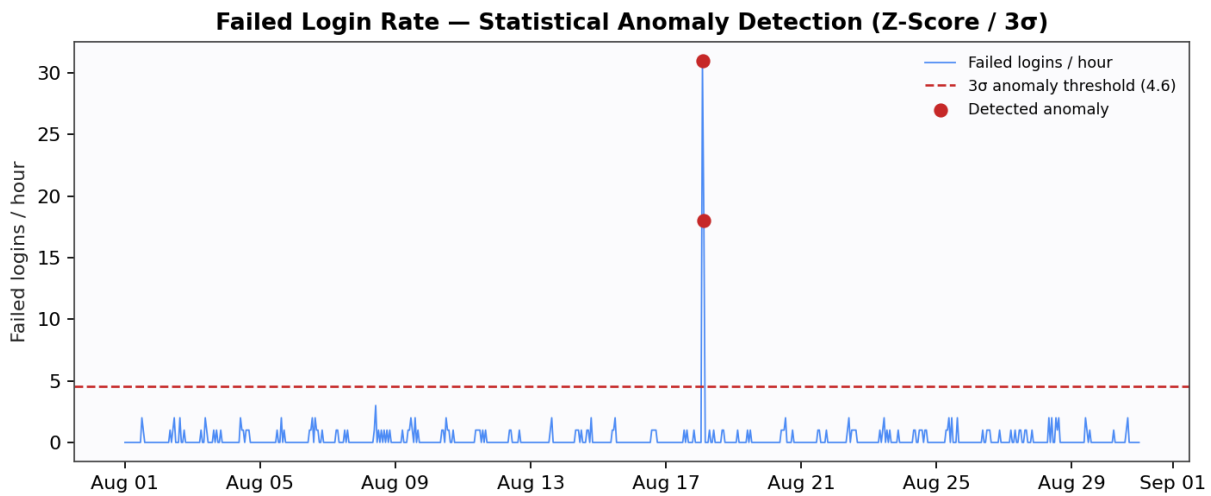


Figure 1 — Failed login rate per hour with 3-sigma statistical anomaly threshold.

The model flagged two consecutive anomalous hours on 18 August 2026 (02:00 and 03:00 UTC), corresponding to 31 and 18 failed authentication attempts respectively against a single account — 20x and 12x the 3-sigma threshold — consistent with automated credential-stuffing tooling rather than human error.

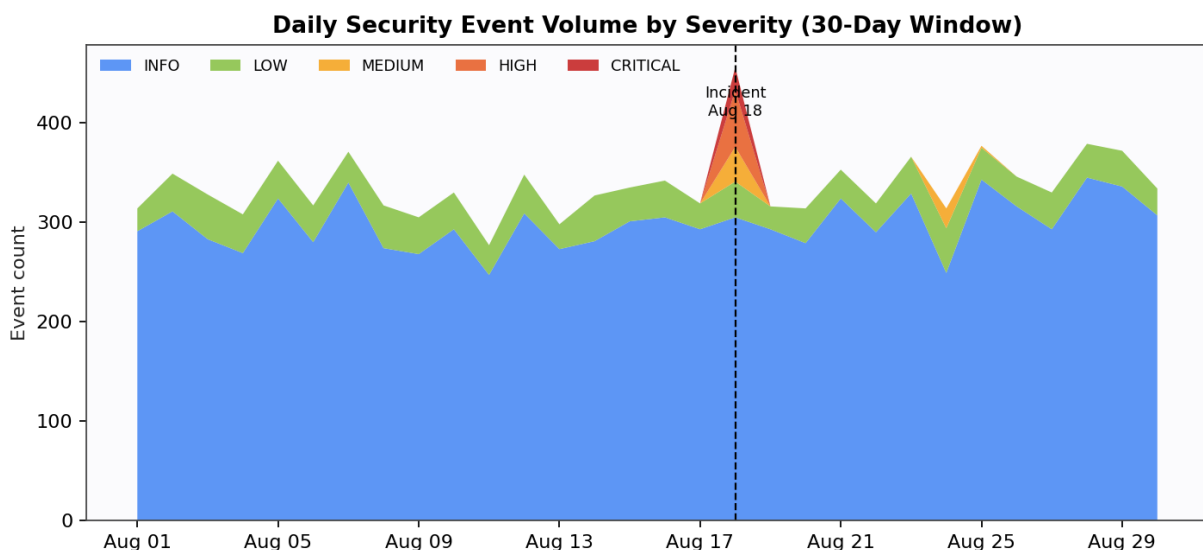


Figure 2 — Daily event volume by severity across the 30-day observation window, showing the isolated spike on 18 August.

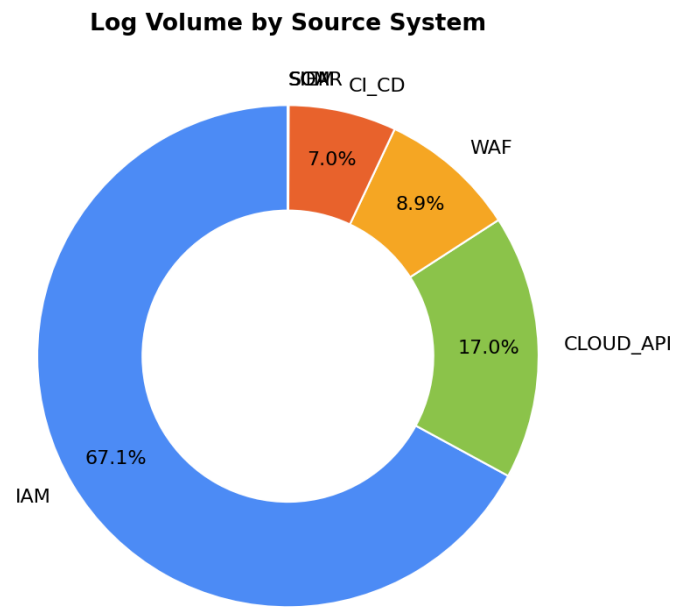


Figure 3 — Log volume distribution by source system, used to validate telemetry coverage across the toolchain.

3.2 Anomaly Findings Summary

#	Anomaly	Detection Method	Severity
1	Impossible travel (IN → RO in 38 min) for user017	Geo-velocity rule + rare-event correlation	CRITICAL
2	MFA push-bombing (9 pushes in 23 min, then approved)	Frequency threshold + rare-event correlation	CRITICAL
3	Privilege escalation immediately after suspicious login	Sequence correlation (login → role change < 30 min)	CRITICAL
4	Force-push bypassing branch protection on payments-api	SCM policy-violation rule	CRITICAL
5	CI/CD pipeline execution outside change window + secret access	Time-window + rare-event correlation	CRITICAL
6	Bulk S3 exfiltration (~3.2 GB in 20 min) from same session	Volume/velocity threshold on data-access API	CRITICAL
7	CloudTrail (audit logging) disable attempt	Rare-event / defense-evasion rule	CRITICAL
8	After-hours bulk access to HR records by user032	Behavioral baseline deviation (time-of-day + data class)	MEDIUM

4. Incident Timeline Analysis

The following reconstructs the confirmed attack chain on 18 August 2026 from correlated log evidence, mapped to standard kill-chain / MITRE ATT&CK-style stages.

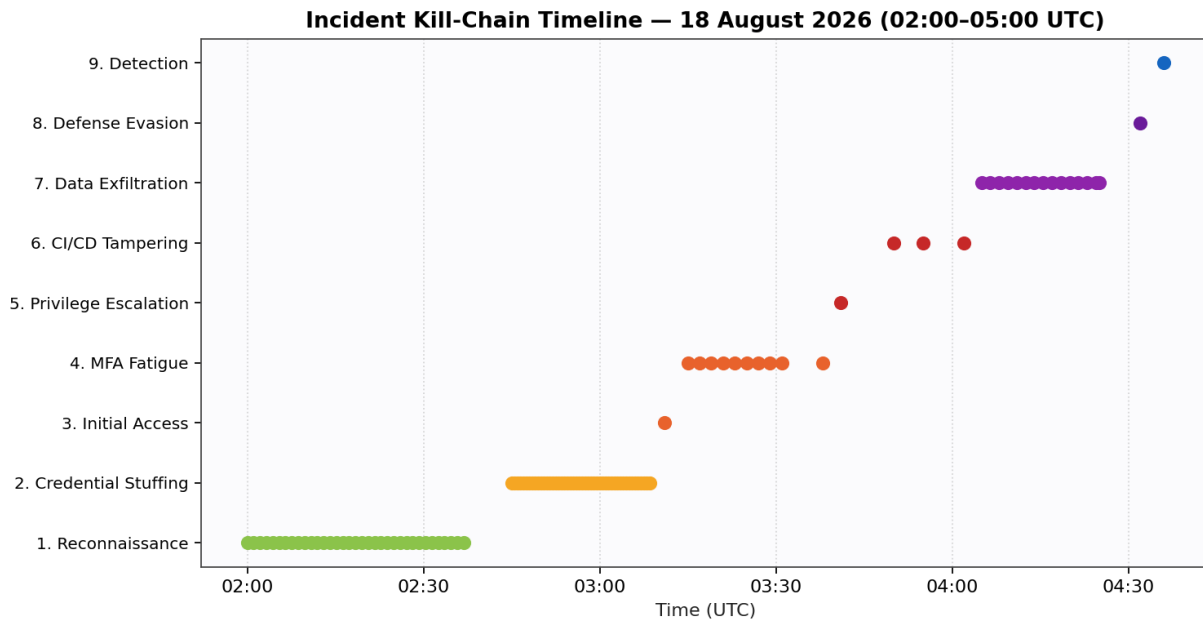


Figure 4 — Reconstructed incident kill-chain timeline, 02:00–05:00 UTC, 18 August 2026.

4.1 Stage-by-Stage Breakdown

Time (UTC)	Stage	Description
02:00 – 02:40	Reconnaissance	35 low-and-slow endpoint enumeration requests (/admin, /users, /config, /internal) from 185.220.101.47, individually below WAF rate-limit thresholds.
02:45 – 03:10	Credential Access	48 failed login attempts against user017@corp.io at a steady ~30s interval — automated credential-stuffing signature.
03:11	Initial Access	Successful login for user017 from Romania, 9,200 km and 38 minutes from the account's last known login in India (impossible travel).
03:15 – 03:38	Persistence / Defense Evasion	9 consecutive MFA push notifications sent in 23 minutes (push-bombing); ultimately approved, indicating either user fatigue-approval or session/token replay.
03:41	Privilege Escalation	user017's role elevated from Developer to Admin via the IAM console — no corresponding change-management ticket.

Time (UTC)	Stage	Description
03:50 – 04:02	Execution (CI/CD Tampering)	Force-push to the payments-api main branch bypassing branch protection; CI pipeline triggered outside the approved deployment window; production database credentials retrieved from the secrets vault.
04:05 – 04:25	Exfiltration	14 large object-retrieval calls against the customer data bucket (~3.2 GB total) followed by modification of the bucket policy to allow public read access.
04:32	Defense Evasion	Attempt to disable the CloudTrail audit logging trail to obscure further activity.
04:36	Detection	SIEM correlation rule fired on the composite pattern: impossible travel + privilege escalation + mass data access within a single session.
04:41 – 04:50	Containment / Recovery	SOAR playbook automatically disabled the compromised account, blocked the attacker IP globally, and on-call SecOps reverted the bucket policy to least privilege.

A secondary, lower-severity anomaly was observed on 24 August 2026: user032@corp.io accessed the HR records repository 22 times between 23:00–24:00 local time, well outside the account's normal working pattern and outside its documented role responsibilities. This was flagged as an insider-risk indicator rather than external compromise, given the absence of anomalous authentication or geo-velocity signals, and is recommended for HR/Legal-partnered review rather than technical containment.

5. Security Monitoring Dashboard

The dashboard below consolidates the key operational metrics a SOC analyst would use to triage this environment, combining volumetric trend visibility with response-time KPIs.

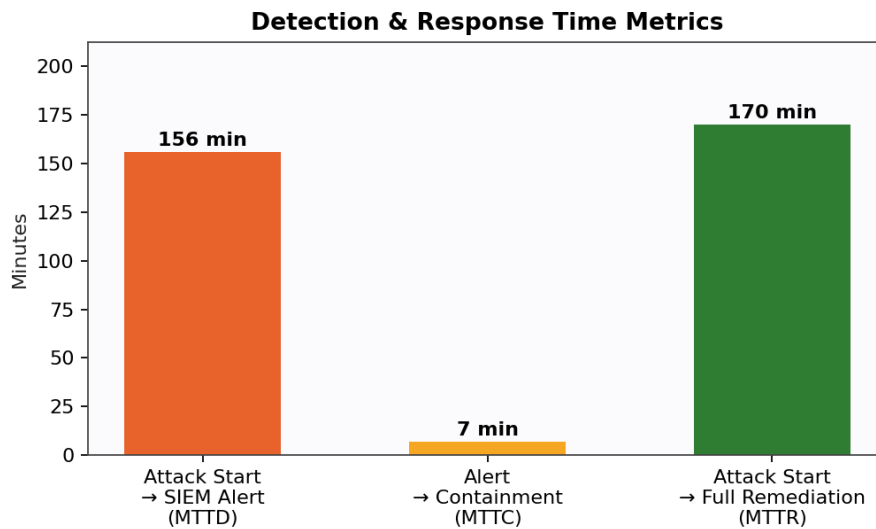


Figure 5 — Detection and response time KPIs for the 18 August incident.

5.1 Key Performance Indicators

KPI	Observed Value	Target SLA	Status
Mean Time to Detect (MTTD)	156 minutes	≤ 15 minutes	MISSED
Mean Time to Contain (MTTC), post-alert	7 minutes	≤ 15 minutes	MET
Total Time to Remediation	170 minutes	≤ 60 minutes	MISSED
Critical-severity events (30 days)	23	Baseline: 0	REVIEW
High-severity events (30 days)	57	Baseline: <5	REVIEW
False-positive rate (WAF bot blocks)	Not applicable to true anomalies (benign)	—	OK
Audit log integrity	1 tampering attempt (blocked by IAM permissions)	0 successful disables	MET

5.2 Dashboard Design Notes

The recommended production dashboard (e.g., in a SIEM such as Splunk, Microsoft Sentinel, or Elastic Security) should surface, on a single pane of glass:

- A rolling 24-hour and 30-day event-volume-by-severity trend (Figure 2) to visually surface deviations from baseline.

- A live failed-authentication rate panel with the statistical anomaly threshold overlaid (Figure 1), alerting when the 3-sigma line is crossed for 2+ consecutive intervals.
- A correlation/kill-chain view (Figure 4) that auto-populates when related high-severity events share an actor, source IP, or session token within a rolling window.
- An MTTD/MTTC/MTTR KPI panel (Figure 5) tracked against SLA, to drive continuous improvement of detection engineering.
- Drill-down capability from any panel to raw log evidence, preserving chain-of-custody for post-incident and potential legal/regulatory review.

6. Incident Response Plan

This Incident Response Plan (IRP) is structured on the NIST SP 800-61r2 lifecycle (Preparation; Detection & Analysis; Containment, Eradication & Recovery; Post-Incident Activity) and is calibrated against the account-takeover / data-exfiltration scenario reconstructed in Section 4.

6.1 Preparation

Goal: Ensure people, process, and technology are ready before an incident occurs.

- Maintain an up-to-date asset and data-classification inventory covering IAM, SCM, CI/CD, and cloud storage, so exfiltrated assets (e.g., the customer data bucket) can be immediately identified and scoped.
- Pre-stage SOAR playbooks for account disablement, IP blocking, session/token revocation, and secrets rotation so containment does not depend on manual, real-time engineering effort.
- Enforce phishing-resistant MFA (FIDO2/WebAuthn) for all privileged and developer accounts to remove push-based MFA as a viable attacker path.
- Conduct quarterly tabletop exercises simulating credential-stuffing-to-exfiltration scenarios, including CI/CD-specific attack paths.
- Maintain a current contact tree (SecOps on-call, engineering leads, Legal, Communications) and pre-approved external counsel/forensics retainer for CRITICAL-severity incidents.

6.2 Detection & Analysis

Goal: Identify the incident quickly and accurately, minimizing MTTD.

- Deploy correlation rules for composite attacker behavior (impossible travel + privilege change + mass data access) rather than relying on single-event alerting, which in this simulation delayed detection to 156 minutes.
- Implement real-time behavioral analytics (UEBA) on authentication and data-access patterns to catch low-and-slow reconnaissance and credential-stuffing before account compromise.
- Triage using a standard severity matrix (Section 6.2 below) to ensure CRITICAL indicators (privilege escalation, secrets access, audit-log tampering) trigger immediate SOC escalation, not queued review.
- Preserve volatile evidence (session tokens, CI/CD run logs, cloud API call records) immediately upon detection to support root-cause analysis and any subsequent legal action.

6.3 Containment, Eradication & Recovery

Goal: Limit damage, remove the attacker's foothold, and restore normal operations safely.

- Short-term containment (as demonstrated by the SOAR playbook): disable the compromised account, block the source IP at WAF/firewall, and revoke active sessions/tokens within minutes of alerting.
- Long-term containment: force a credential and secrets rotation for every credential the compromised session could have accessed (CI/CD runner tokens, database credentials retrieved from the vault, any keys embedded in the tampered commit).
- Eradication: revert the unauthorized commit and CI/CD pipeline changes, rebuild affected container images from a known-good baseline, and restore the S3 bucket policy to least privilege (partially demonstrated in this scenario at 04:50).
- Validate CloudTrail/audit logging integrity and re-enable/verify any logging the attacker attempted to disable before declaring recovery.

- Recovery: stage a phased return to production for the affected repository (payments-api) with mandatory code review and security scanning gates before redeployment; monitor closely for 14 days post-incident.

6.4 Post-Incident Activity

Goal: Learn from the incident and reduce recurrence likelihood.

- Conduct a blameless post-incident review within 5 business days, documenting root cause (susceptibility to MFA fatigue and absent rate-limiting on authentication) and the 156-minute detection gap.
- Update detection content and SLAs based on the MTTD/MTTC results in Section 5.1; track remediation of identified gaps to closure.
- Assess regulatory and contractual notification obligations given the exfiltration of customer data (e.g., breach notification timelines under applicable data protection law) in coordination with Legal.
- Feed confirmed indicators of compromise (attacker IP, TTPs) into threat intelligence and detection engineering backlogs.

6.5 Severity & Escalation Matrix

Severity	Example Trigger	Response Time Target	Escalation Path
CRITICAL	Privilege escalation, secrets access, confirmed exfiltration, audit-log tampering	Immediate (< 15 min)	SOC → IR Lead → CISO → Legal/Exec (if data breach)
HIGH	Credential-stuffing pattern, impossible travel, repeated MFA prompts	< 30 min	SOC → On-call Engineer → IR Lead
MEDIUM	Behavioral deviation (after-hours access), policy violations	< 4 hours	SOC → Relevant data/system owner
LOW / INFO	Bot/scanner blocks, routine failed logins	Next business day / automated	Logged for trend analysis only

7. Recommended Mitigation Strategies and Technical Justification

The following prioritized recommendations map directly to the attack stages and root causes identified in Sections 3 and 4.

7.1 Adaptive Rate-Limiting & Credential-Stuffing Defense

Risk Addressed: 48 automated login attempts succeeded in bypassing basic controls within 25 minutes.

Recommendation: Implement adaptive, risk-based rate-limiting on authentication endpoints (e.g., exponential backoff after 5 failures/account/10 min) combined with IP reputation and Tor/proxy-exit blocking at the WAF layer.

Technical Justification: Static per-account lockouts are trivially evaded by distributed credential stuffing; adaptive controls that combine velocity, IP reputation, and device fingerprinting reduce brute-force success probability by orders of magnitude while minimizing legitimate-user friction, and directly close the gap exploited in Stage 2 of the incident.

Priority: CRITICAL

7.2 Phishing-Resistant MFA (Eliminate Push-Bombing Risk)

Risk Addressed: Attacker obtained MFA approval after 9 consecutive push notifications (push-bombing / MFA fatigue).

Recommendation: Replace push-based MFA with phishing-resistant, number-matching or FIDO2/WebAuthn hardware-bound authentication for all privileged and engineering accounts; enforce a maximum push-retry limit with automatic account lock and alert after 3 prompts.

Technical Justification: Push notifications without number-matching provide no cryptographic binding to the legitimate login attempt and are a well-documented bypass for MFA; FIDO2/WebAuthn requires physical possession of a registered authenticator and is resistant to both fatigue and real-time phishing/relay attacks, eliminating the exact technique used in Stage 4.

Priority: CRITICAL

7.3 Composite Behavioral Correlation & UEBA

Risk Addressed: MTTD of 156 minutes; individual events (single failed logins, single scan attempts) were each below existing single-event thresholds.

Recommendation: Deploy User and Entity Behavior Analytics (UEBA) and multi-signal correlation rules that score sessions on combined risk factors (geo-velocity, privilege changes, data-access volume, time-of-day) rather than isolated thresholds, with automated CRITICAL-severity alerting.

Technical Justification: Attackers deliberately keep individual actions below naive rate thresholds (Stage 1 reconnaissance used 65-second intervals). Composite/behavioral scoring detects the aggregate anomaly of a session — as demonstrated by the correlation rule that ultimately fired in this simulation — and can move detection from hours to minutes if tuned and enabled proactively rather than reactively.

Priority: CRITICAL

7.4 CI/CD Pipeline Hardening & Branch Protection Enforcement

Risk Addressed: Force-push bypassed branch protection on a production repository; pipeline executed outside the approved change window.

Recommendation: Enforce non-bypassable branch protection (no force-push, required signed commits, mandatory PR review + status checks) at the platform/organization level; gate pipeline execution to approved

change windows with break-glass exceptions requiring dual approval; run software composition/IaC scanning pre-merge.

Technical Justification: Branch protection settings that can be overridden by a compromised account with elevated privileges provide no real security boundary. Organization-enforced (non-repo-overridable) policies and out-of-band change-window gating ensure that even a successfully escalated account cannot silently modify production deployment artifacts, directly preventing Stage 6 of the observed kill chain.

Priority: HIGH

7.5 Secrets Management & Least-Privilege for CI Runners

Risk Addressed: CI runner accessed production database credentials directly from the secrets vault during an anomalous, out-of-window pipeline run.

Recommendation: Scope CI/CD runner identities to short-lived, task-specific credentials issued just-in-time (e.g., via workload identity federation) rather than standing vault access; alert on any secrets access outside a recognized, scheduled pipeline run signature.

Technical Justification: Standing broad-access credentials for automation accounts are a high-value target precisely because compromising the account (or the pipeline that uses it) yields the same blast radius as compromising a human admin. Just-in-time, narrowly scoped credentials limit exposure to the lifetime of a single legitimate task and make anomalous access immediately detectable.

Priority: HIGH

7.6 Data Loss Prevention & Egress Controls on Cloud Storage

Risk Addressed: ~3.2 GB exfiltrated via 14 bulk object-retrieval calls; bucket policy was subsequently modified to allow public access.

Recommendation: Apply DLP/volume-based anomaly alerting on object storage (flag bulk retrieval exceeding historical per-user/per-session baselines), enforce Service Control Policies preventing public-read bucket policy changes outside a approved change-management workflow, and enable object-level access logging with immutable storage.

Technical Justification: Preventive guardrails (SCPs) that block public-exposure policy changes regardless of the acting principal's IAM permissions provide defense-in-depth against exactly this kind of post-compromise action, while volume-based DLP alerting shortens the exfiltration detection window even if initial access controls fail.

Priority: HIGH

7.7 Immutable, Tamper-Evident Audit Logging

Risk Addressed: Attacker attempted to disable the CloudTrail audit trail to cover their tracks.

Recommendation: Route all audit logs to a separate, write-once/immutable log store (e.g., object-lock enabled bucket in a distinct account with restricted cross-account access) and alert immediately on any attempt to modify or disable logging configuration, treating it as an inherently CRITICAL event regardless of the acting identity's apparent authorization.

Technical Justification: Centralizing logs outside the blast radius of the primary account, with immutability enforced at the storage layer, ensures forensic evidence and detection capability survive even a successful privilege-escalation event — closing the defense-evasion gap exploited in Stage 8.

Priority: MEDIUM

7.8 Insider Risk Monitoring for Sensitive Data Repositories

Risk Addressed: After-hours bulk access to HR records by an account without a documented business need.

Recommendation: Implement data-classification-aware behavioral baselines for sensitive repositories (HR, finance, legal) with alerting on time-of-day and volume deviations, paired with a defined HR/Legal-partnered review workflow distinct from the technical SOC containment process.

Technical Justification: Insider-risk indicators require a different response track than external compromise (no technical control bypass may have occurred), and routing them to HR/Legal early prevents both under-reaction (ignoring policy violations) and over-reaction (treating routine access as a security incident) while preserving evidentiary chain-of-custody if escalation becomes necessary.

Priority: MEDIUM

8. Conclusion

The simulated 30-day telemetry set and embedded multi-stage attack scenario provided a realistic basis for evaluating detection coverage, response timeliness, and control gaps across the DevSecOps toolchain. While automated containment performed well once alerted (7-minute MTTC), the 156-minute detection gap represents the most significant risk exposure and stems primarily from single-event, threshold-based alerting rather than composite behavioral correlation. Implementing the eight prioritized mitigations in Section 7 — particularly phishing-resistant MFA, adaptive rate-limiting, and behavioral correlation — would be expected to prevent or substantially shorten the kill chain observed in this assessment, reducing MTTD toward the target SLA of 15 minutes and eliminating several of the escalation paths used by the simulated attacker.